

TASK-5

Research three recent malware incidents, describe their attack methods, and explain how each was mitigated or resolved. Submit it as a PDF or Markdown file.

Malware Incident Analysis Report

Incident 1: LAPSUS\$ Group Attacks (Social Engineering and MFA Bypass):

Malware Type:

- Not traditional file-based malware; relies on stolen credentials and social engineering to gain access.

Attack Method:

- The LAPSUS\$ group specialized in Multi-Factor Authentication (MFA) bypass and insider threats. Their primary method involved: 1. Credential Acquisition: Buying credentials on dark web marketplaces or using commodity malware (like RedLine Stealer) to harvest credentials. 2. Social Engineering: Executing SIM-swapping (taking over an employee's mobile number) or vishing (voice phishing) to trick employees into approving MFA prompts on stolen accounts. 3. Privilege Escalation: Once inside the network, they searched source code repositories, collaboration platforms (like GitHub/Slack), and internal documents for additional privileged credentials to expand their access and exfiltrate sensitive data.

Mitigation & Resolution:

- The defense against LAPSUS\$ centered on zero-trust principles and hardened authentication: 1. Phishing-Resistant MFA: Migrating users from weak MFA methods (like SMS or simple push notifications) to phishing-resistant methods such as FIDO2/WebAuthn hardware tokens (security keys). 2. Zero Trust & PAM: Implementing a Zero Trust architecture and Privileged Access Management (PAM) to strictly limit lateral movement and require re-authentication for accessing critical resources. 3. Enhanced Monitoring: Aggressively monitoring logs for MFA fatigue attacks (repeated MFA requests) and using geofencing/Geo-blocking to flag remote access from unusual locations, especially immediately following a compromised account login.

Malware Incident Analysis Report

Incident 2: BlackSuit Ransomware (Double Extortion & Encryption):

Malware Type:

- Ransomware and Data Extortion Group (DEG).

Attack Method:

- BlackSuit uses a Double Extortion model: 1. Initial Access: Gained via exploiting vulnerabilities in perimeter devices, exposed Remote Desktop Protocol (RDP) endpoints, or through targeted phishing attacks. 2. Lateral Movement & Data Theft: Once inside, they used tools like Mimikatz for credential harvesting and then exfiltrated massive amounts of sensitive data from the victim's network. 3. Encryption: Only after exfiltration did they deploy the BlackSuit ransomware payload, which uses strong encryption algorithms to lock files and critical systems. The double threat is: pay to decrypt files, or pay to prevent the public leak of stolen data

Mitigation & Resolution:

- Mitigation focuses on preventing initial access and ensuring recovery capability: 1. Offline Immutable Backups: Adopting the 3-2-1 backup rule and specifically ensuring that one set of backups is immutable (cannot be deleted or modified) and air-gapped/offline from the main network to prevent ransomware from reaching and encrypting backup copies. 2. Patch Management: Prioritizing and immediately patching all internet-facing devices, especially VPNs, firewalls, and mail servers, which are common initial access points. 3. Network Segmentation & EDR: Implementing strict network segmentation to contain a breach. Deploying Endpoint Detection and Response (EDR) tools configured to detect and block the bulk encryption activity that is characteristic of ransomware.

Malware Incident Analysis Report

Incident 3: Oracle E-Business Suite (EBS) Zero-Day Exploitation

Malware Type:

- Zero-Day Exploit leading to a custom, fileless Java Webshell.

Attack Method:

- Threat actors (sometimes associated with groups like SCATTERED LAPSUS\$ HUNTERS) exploited a zero-day vulnerability (CVE-2025-61882) in Oracle EBS:
1. Exploit Chain: The attack involved sending malicious payloads to exposed Oracle application endpoints (like `UiServlet` or `SyncServlet`).
2. In-Memory Dropper: This exploit allowed the actor to drop a custom, fileless Java reflective class loader (`SAGEGIFT`) directly into the EBS memory space.
3. Persistence: This loader was used to install a malicious Java servlet filter (`SAGEWAVE`), which served as a backdoor, allowing the attacker continued remote access and command execution without leaving a file on disk.

Mitigation & Resolution:

- Resolution required vendor-specific patching and deep monitoring:
1. Emergency Patching: Oracle released emergency Critical Patch Updates (CPUs) that addressed the zero-day vulnerabilities. Applying these vendor patches immediately was the most crucial step.
2. Database & Template Cleanup: As the actors stored secondary payloads and configuration within EBS database tables (e.g., `XDO_TEMPLATES_B`), security teams had to run specific SQL queries to hunt for and delete malicious templates hidden in the database.
3. Outbound Connection Restriction: Restricting non-essential outbound internet access from the EBS application servers. This prevents the initial in-memory payload from phoning home to its Command and Control (C2) server to fetch later-stage implants or exfiltrate data.